Aprendizagem Aplicada à Segurança

Class 7: Anomaly Detection III, testing the detectors as an adversary would

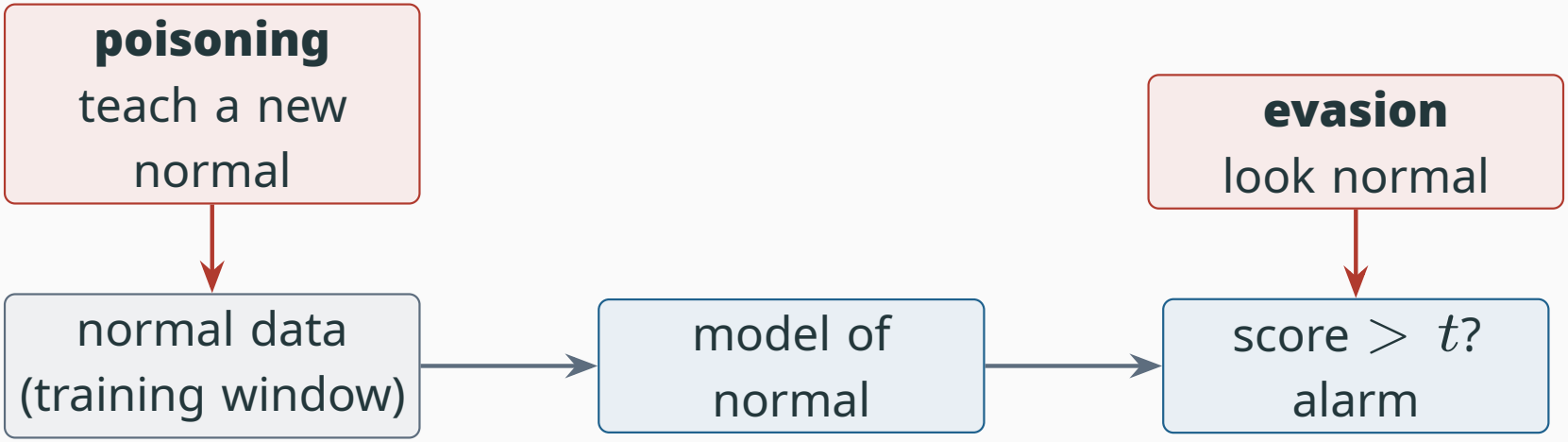
Mário Antunes

October 30, 2026

Universidade de Aveiro

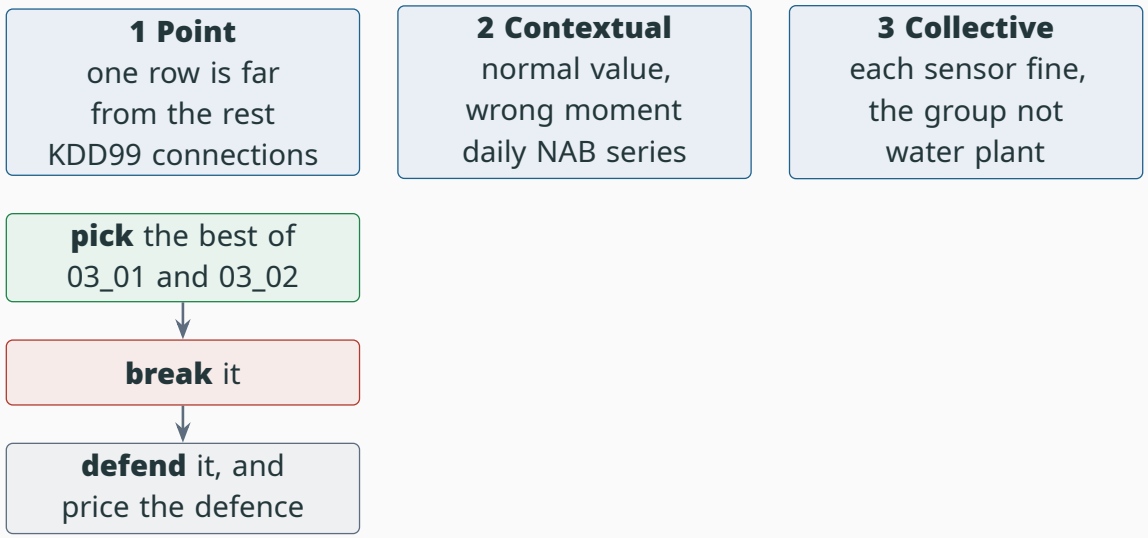
An anomaly detector faces someone who adapts

- Spam (class 04): change the words. What is the equivalent for an anomaly detector?



- Today: play the adversary against **our own** detectors to learn what their alarms rest on.

Three kinds of anomaly, one routine



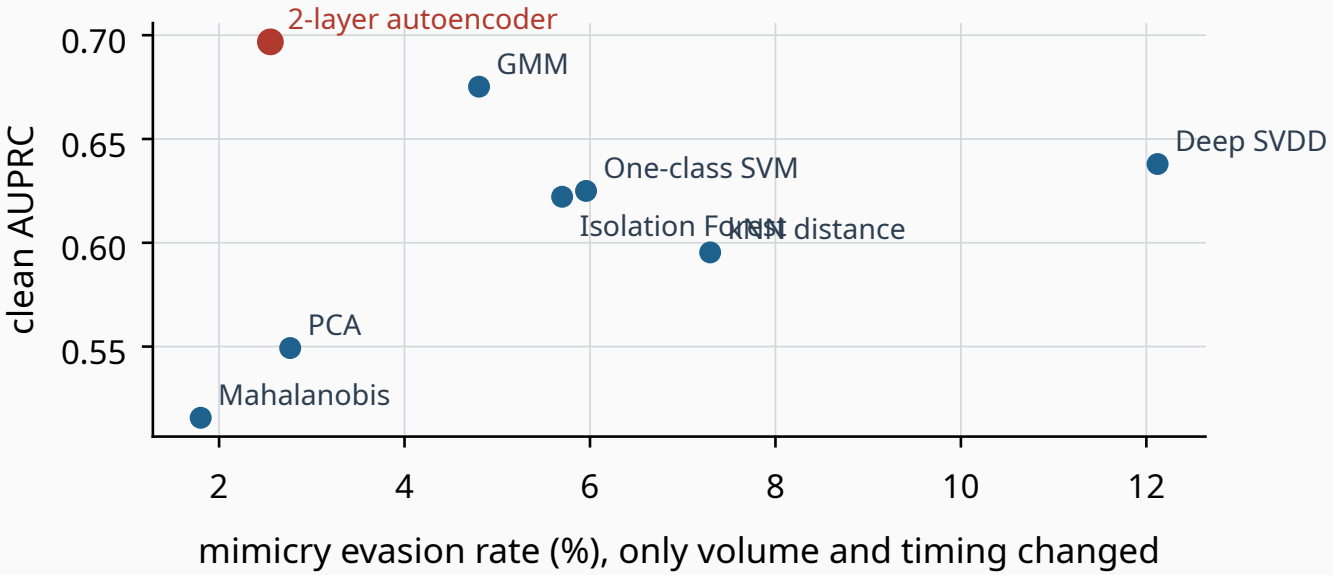
- Each part runs the same routine on its own data: notebooks 07, 08 and 09.
- The best detector is picked **by the numbers** of the earlier classes, never by the attack.

Terminology: scope and threat model

- Our models, public or synthetic data, offline, in **feature space**; the aim is the defender's.
- A result means something only with its **threat model** (Biggio et al. 2013; Vassilev et al. 2025):

Element	Question
goal	evasion (test time) or poisoning (training time)?
capability	which features, sensors or values can change without changing the attack?
knowledge	normal data? scores? the model itself?
cost	queries, edits, rounds, sensors owned, slower attack

Pick the best, then see how it breaks

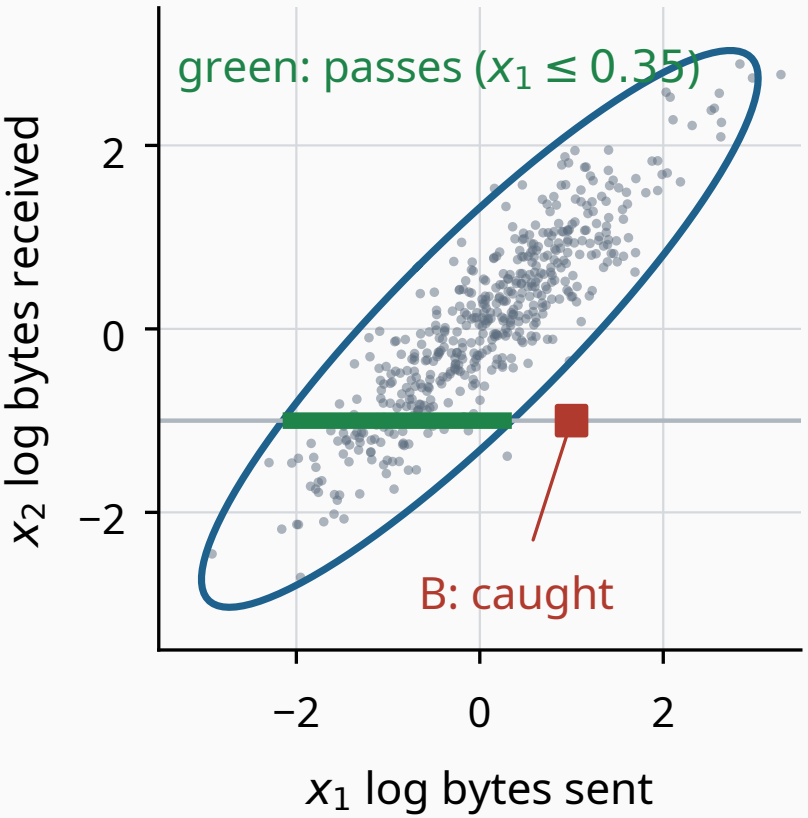


- Best by AUPRC: the 2-layer autoencoder (0.70), then the GMM (0.68).
- It resists mimicry well (2.6% evasion); Deep SVDD is the weakest (12.1%).
- It breaks elsewhere: its threshold and its training data.

Constraints: an attack must stay an attack

- In spam any word could be added. A network connection is not free text:
- **Fixed**: protocol, service, flag, error rates, failed logins, root shells: what the attack *does*.
- **Mutable**: duration, bytes, connection counts: volume and timing.
- An “evasion” that changes a fixed feature is a different (often harmless) connection: it does not count.
- Feature-space results are an upper bound of what traffic can achieve (Han et al. 2021).

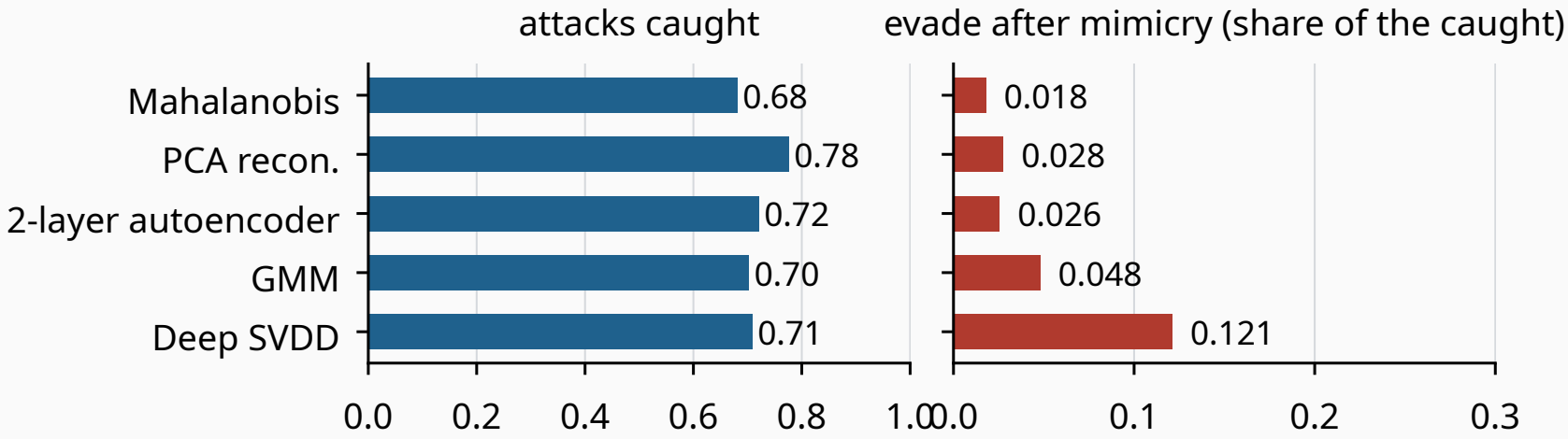
Example 1: evasion has a price



- B $= (1, -1)$ must pass the Mahalanobis detector at 1% FPR ($d_M^2 \leq 9.21$) keeping $x_2 = -1$.
- That needs $x_1 \leq 0.35$ (derivation: appendix).
- B passes only by sending **less per session**: a **slower** attack lasts longer.

Mimicry on KDD99: borrow normal volume and timing

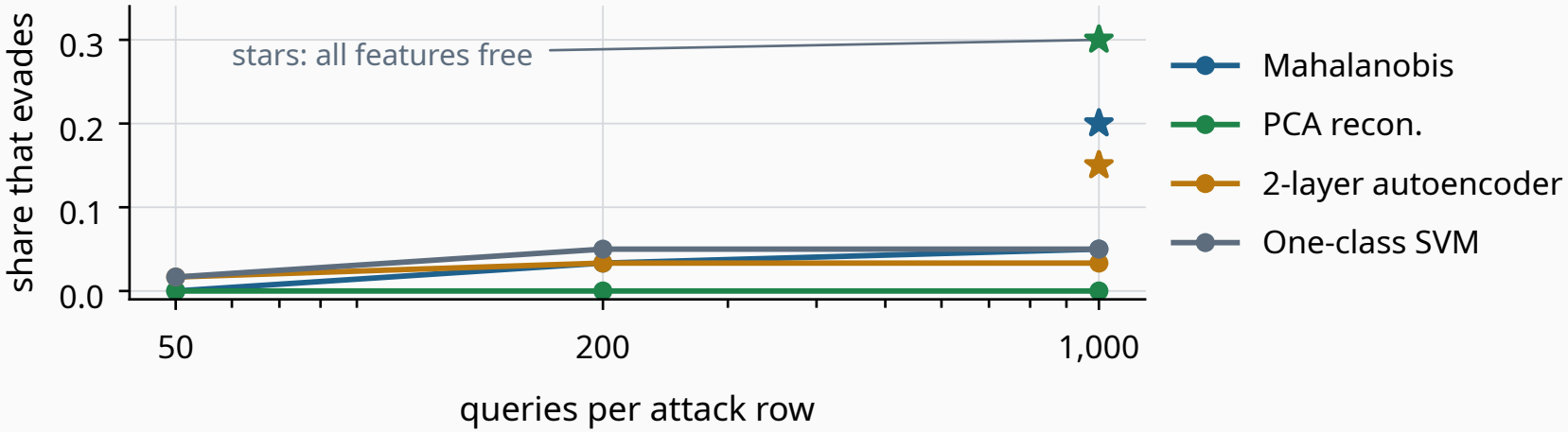
- For each caught attack, take the nearest normal row in the **fixed** features; copy its **mutable** ones (Wagner and Soto 2002).



- No query is needed. Evasion is rare: detectors catch attacks by what they **do**, not by size.
- The r2l and u2r rows, near the threshold, evade first.

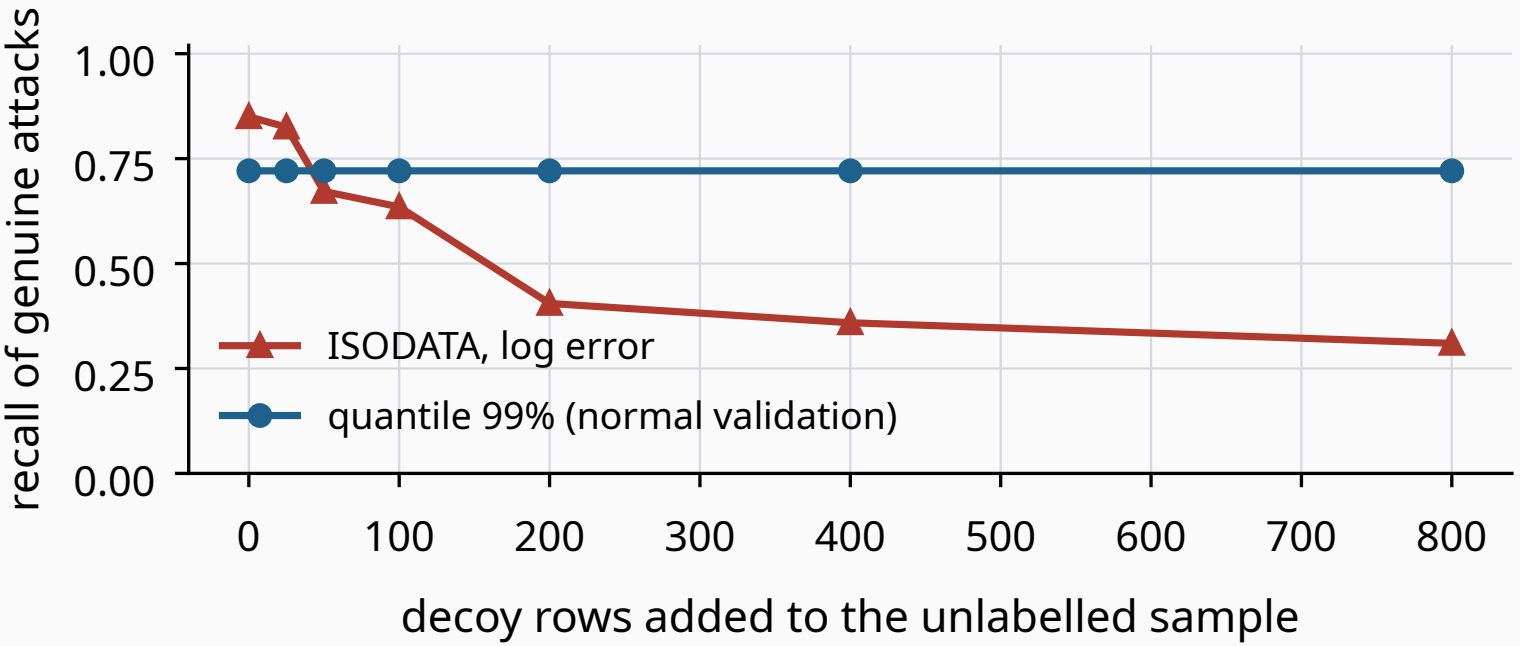
Black-box search with a query budget

- Per query the attacker sees a score; a random step on one mutable feature is kept if the score drops.



- Share of 60 caught attacks that evade: at most 5% with the constraint; free every feature (stars) and it reaches 15-30%.
- The **feasible region**, not the search, is the limit.

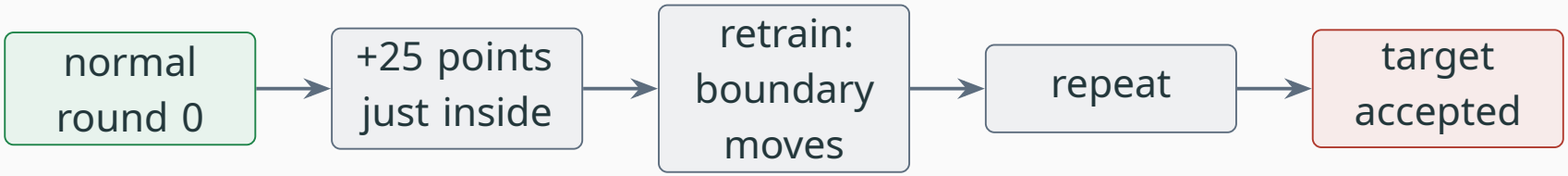
Break the threshold, not the model



- An ISODATA threshold (class 03_02) follows the rows in its sample: 800 decoys cut recall from 0.85 to 0.31.
- The quantile of clean validation rows does not move (0.72): the attacker cannot write there.

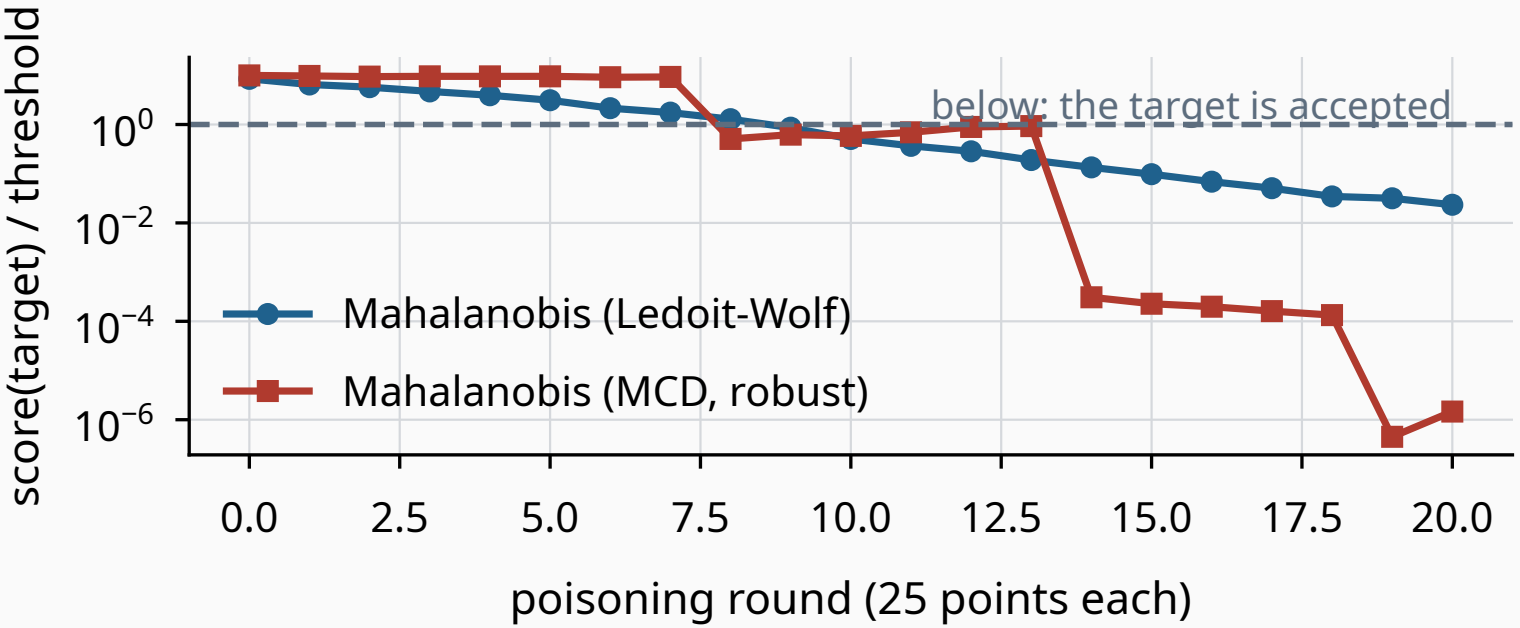
The boiling frog

- A detector retrained on recent traffic follows legitimate change, and also an attacker's.
- Each round the attacker adds points just **below** the threshold, toward the target (Rubinstein et al. 2009; Kravchik and Shabtai 2020).



- Example 1, target $(2, -2)$, $d_M^2 = 77.7$ under the clean model; window of 500 points.

Robust statistics do not stop a patient attacker

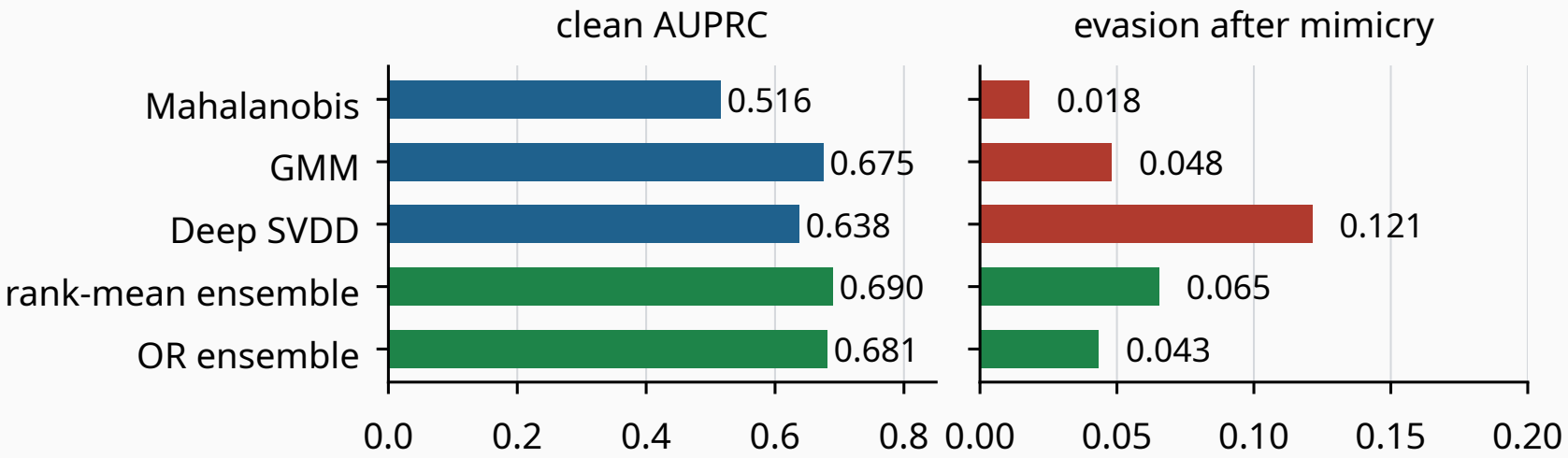


- Both estimators accept the target after 8 or 9 rounds (200 to 225 poison points, 40-45% of the window).
- MCD discards *scattered* outliers; the poison is a tight cluster that MCD keeps.
- Robust estimators do not stop an adaptive adversary.

DEMO 07

notebooks/02-anomaly/notebook_07.ipynb

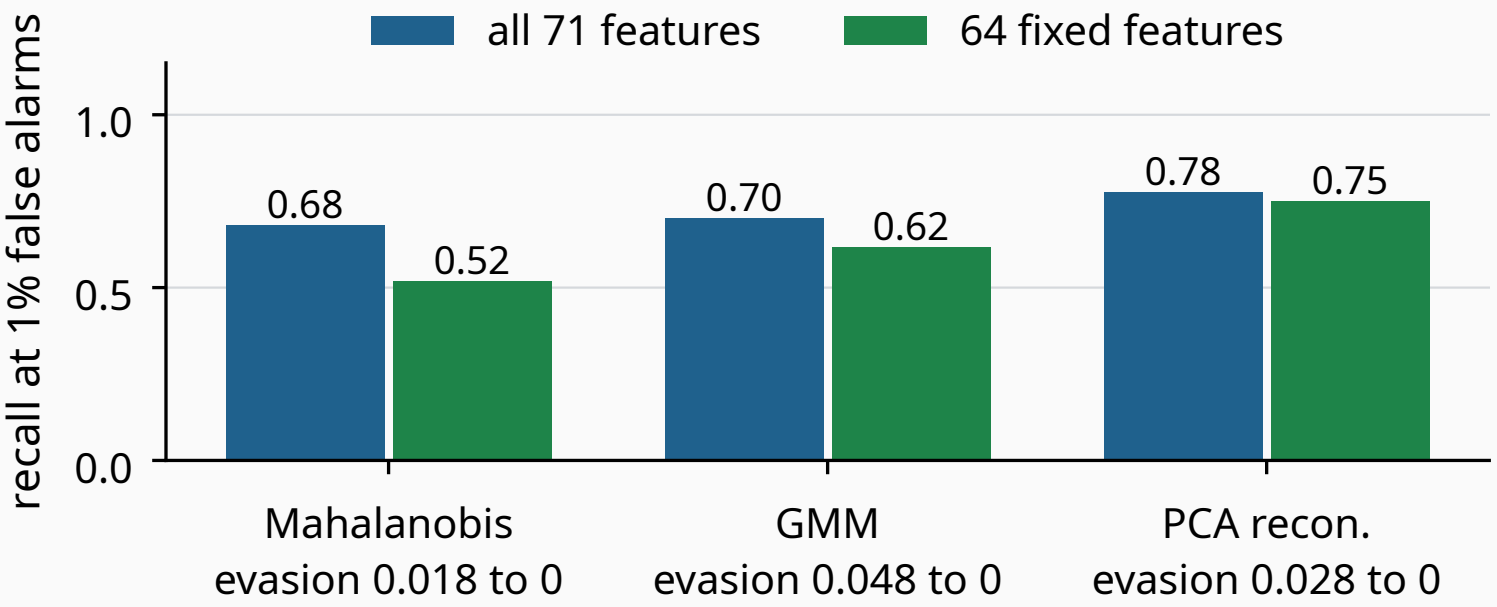
Defend: ensembles, robust features, vetting



- **Rank mean** (average of ranks) matches the best single detector (0.69); its robustness lies *between* its members'.
- **OR** (any member alarms, each at $1\%/m$) is stricter but adds false alarms.

Robust features: score only what the attack needs

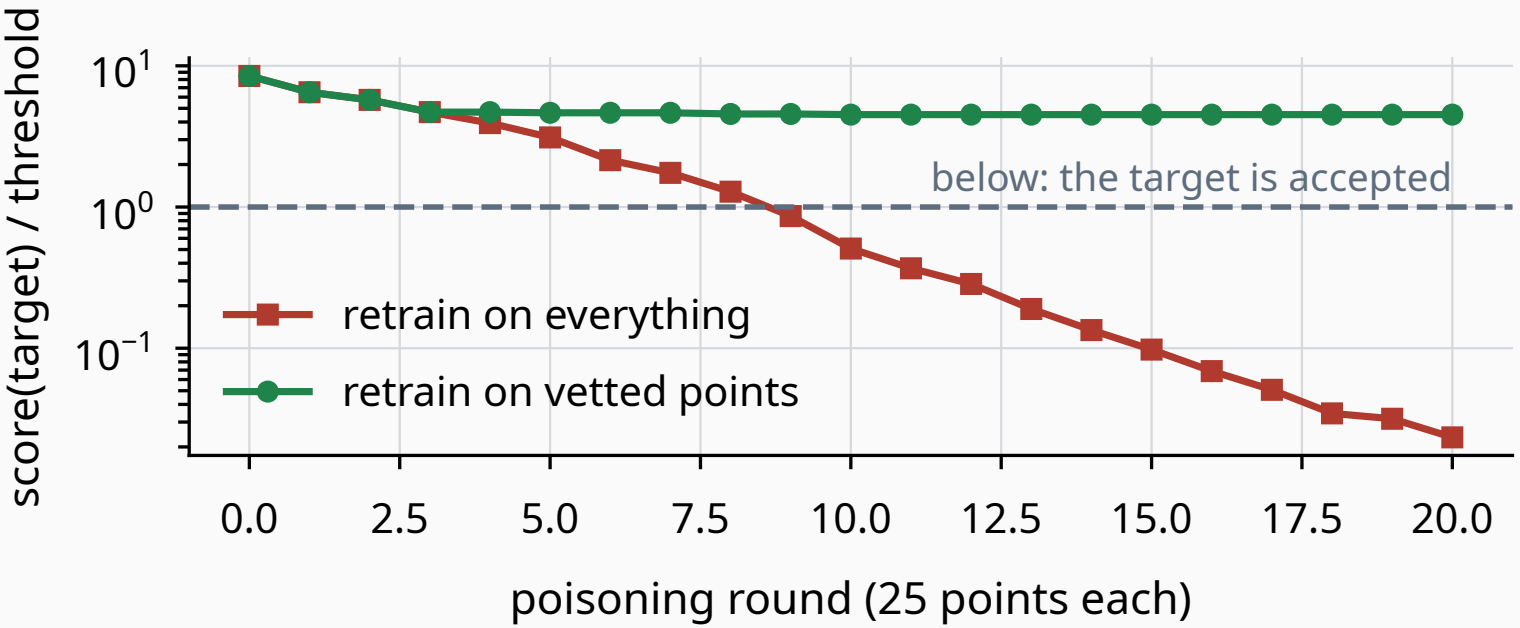
- Fit on the 64 **fixed** features: mimicry of volume and timing cannot move the score.



- PCA loses little, Mahalanobis a quarter of its recall: choose by what an attacker can change, then **measure**.

Vetted retraining against the boiling frog

- Keep a **frozen reference** fitted once on trusted data.
- Retrain only on points it accepts (0.1% false alarms).



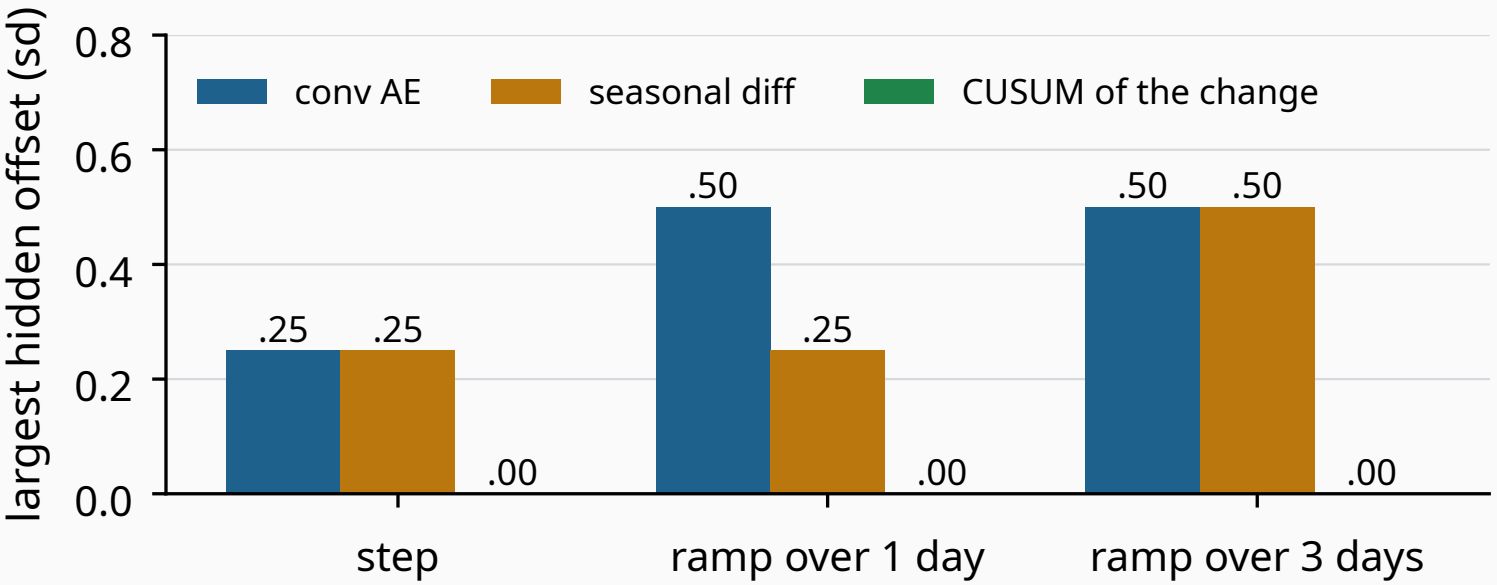
- 56 of 500 poison points pass the vetting; the model moves a little, then stops: the target is never accepted.

Pick the best: a conv AE, on a protocol

	|x|	seasonal diff	moving std 1h	conv AE
jumpsup	found, 0	found, 114	found, 1	found, 0
jumpsdown	missed	found, 112	missed	found, 3
nojump	missed	found, 108	missed	found, 35
flatmiddle	missed	found, 355	missed	found, 1

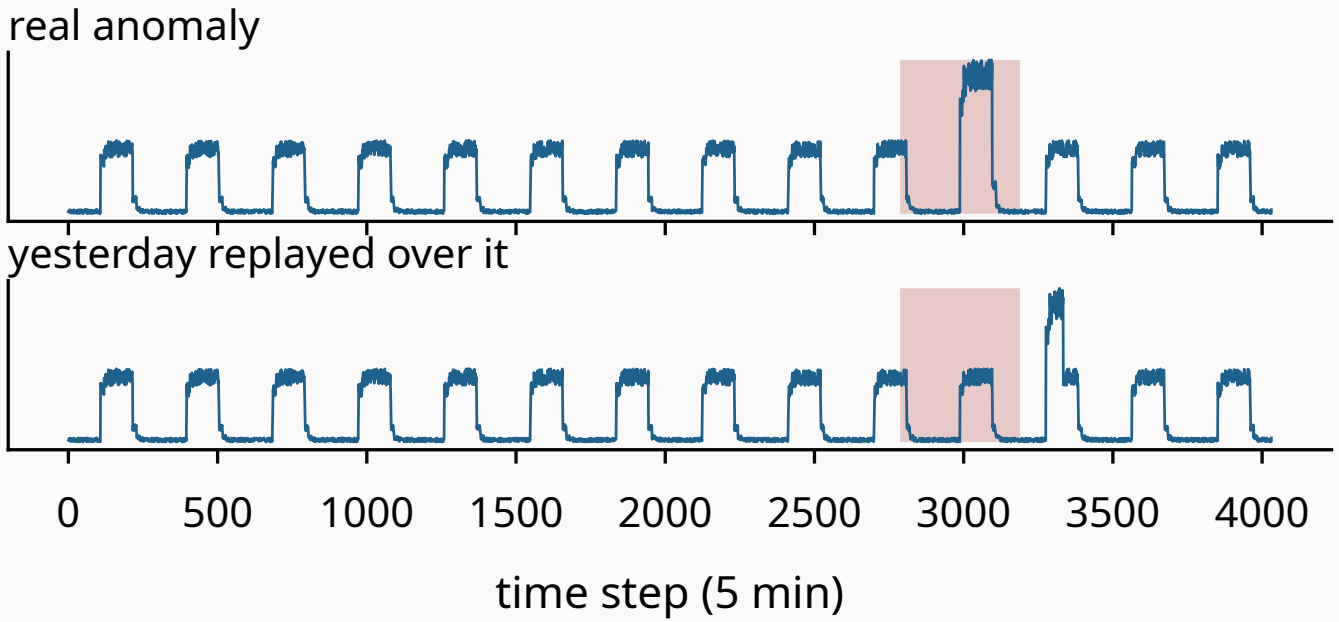
- A **contextual** anomaly: normal value, wrong moment. Four NAB series, train on days 1-8, threshold from day 9.
- Best: the conv AE finds all four with 39 false alarms; the seasonal difference finds all four but echoes (689).
- $|x|$ and the moving std find one each.

Break it: a ramp hides an offset



- Add an offset from day 10, at once or growing over 1 or 3 days; the largest offset with no hour of alarms.
- Step: 0.25 sd for both detectors. A 3-day ramp lifts it to 0.5 sd: a ramp has no edge to see.
- The daily swing is 2.5 sd: the best detector tolerates a fifth of it for days.

Break it: replay yesterday



- Replay the previous normal day over the anomaly: every value is a real normal one.
- The seasonal difference finds nothing; the conv AE flags only the seams. Detectors check consistency, not truth.

DEMO 08

notebooks/02-anomaly/notebook_08.ipynb

Defend: accumulate, vote, add a second source

- **CUSUM** (Page 1954) adds up small deviations z_t (here the day-over-day change); alarm if $S_t > h$:

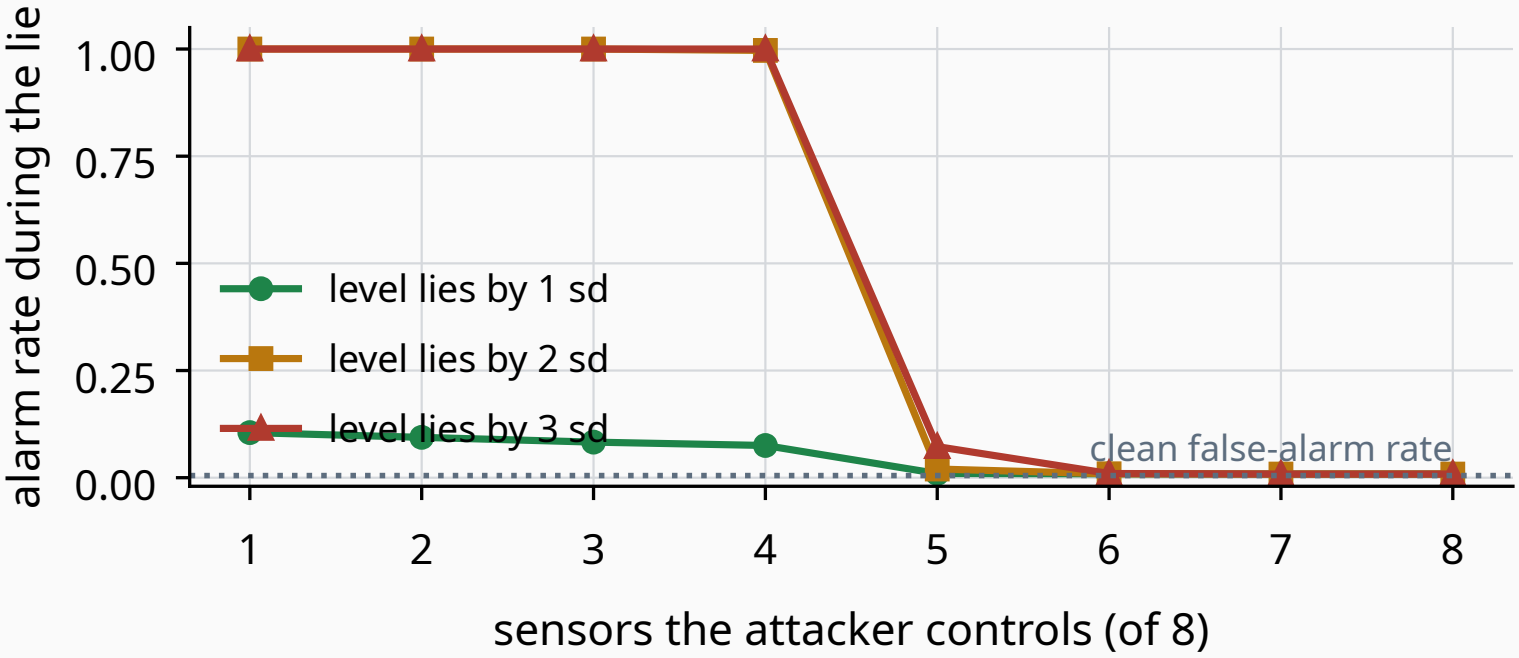
$$S_t = \max\left(0,\ S_{t-1} + (z_t - \mu)/\sigma - k\right) \quad \text{(definition)}$$

- Blind spot below 0.25 sd, at the price of the noisiest alarms (213 steps); **vote** between detectors that fail differently.
- A **replay** needs a second source of the same quantity: another sensor, a log, a person.

Pick the best: PCA on the sensors

- Eight sensors, two hidden processes; events: a spike, a **freeze** (stale value) and a **drift**.
- Best by AUPRC: PCA reconstruction over the sensors (0.60), the only one that finds all three with 14 false alarms.
- Conv AE over space and time (0.45) and predict-from-the-others (0.41) follow; per-sensor $|z|$ finds only the spike.

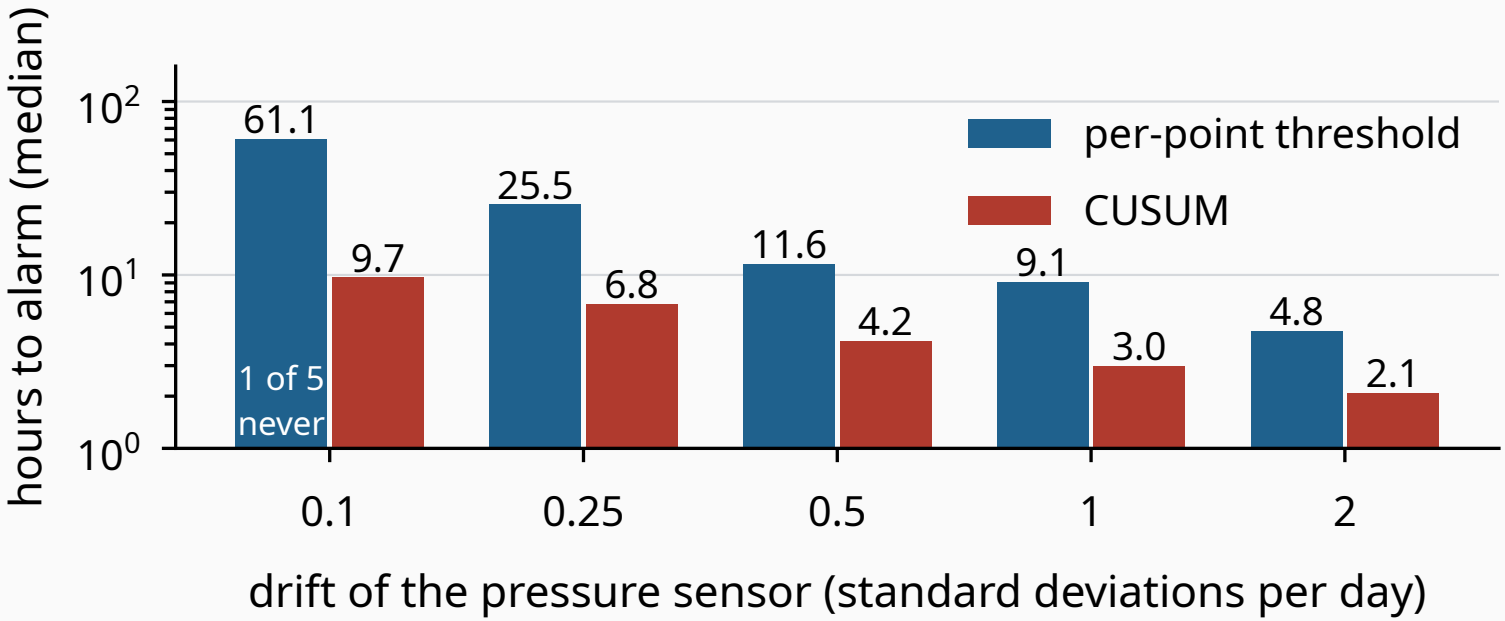
Break it: a lie that keeps the correlations



- The residual is linear, $\mathbf{r} = A\mathbf{x}$: the attacker shifts owned sensors to minimise $\|A\delta\|$ (appendix).
- A 2-sd lie on level: detected with 1 to 4 sensors owned, hidden (alarm 2%) with 5 of 8. No query needed.

Break it: a slow drift under a per-point threshold

- The pressure sensor drifts slowly; the per-point residual stays under its threshold for hours.
- **CUSUM** (part 2) on the residual r_t fires within 2 to 10 hours (median of 5 runs, no false alarms).



DEMO 09

notebooks/02-anomaly/notebook_09.ipynb

Defend: guard sensors and accumulation

- A **guard** is a reading the attacker cannot write (a separate network, a second instrument).
- With one guard the lie needs all 7 unguarded sensors; with two, 17 of the 21 guard pairs make it impossible.
- CUSUM catches the drift within 2 to 10 hours, but adds nothing against the lie: no residual to add up.

Every defence has a price and an answer

Part	Best detector	What broke it	What helps	Cost
1 point	2-layer AE	mimicry (all features), decoys, poison	robust features, vetting, clean validation	recall
2 con-textual	conv AE	ramp under 0.5 sd, replay	CUSUM of the change, second source	false alarms
3 col-lective	PCA residual	lie on owned sensors, drift	guards, CUSUM	unreachable instruments

- **No defence is final; each changes the price.** Report clean metrics *and* robustness.

Labs and practice guide

Notebook	Content
07	part 1: pick, Example 1 price, mimicry, black box, threshold decoys, boiling frog, defences
08	part 2: pick, hidden offset and ramp, retraining on the offset, frozen reference
09	part 3: pick, coordinated lie, slow drift and CUSUM, guard sensors

- **Guide** `practice/anomaly/guide_03_03`: mimicry, a budgeted black-box search, the boiling frog with and without vetting, CUSUM.

Take-aways

- The best detector is not the safest: every kind of anomaly has its own weak point.
- Point: volume and timing are cheap to fake; the threshold and the training window are part of the attack surface.
- Contextual: a slow ramp and daily retraining teach a model any new normal; keep a frozen reference.
- Collective: correlations are only as safe as the sensors an attacker cannot touch.
- Measure every defence twice: on clean data and under attack.

Solving Example 1's evasion

- Constraint: $(x_1^2 - 1.8x_1x_2 + x_2^2)/0.19 \leq 9.21$ with $x_2 = -1$.
- Multiply by 0.19: $x_1^2 + 1.8x_1 + 1 \leq 1.75$, so $x_1^2 + 1.8x_1 - 0.75 \leq 0$.
- Roots: $x_1 = \frac{-1.8 \pm \sqrt{1.8^2 + 4 \cdot 0.75}}{2} = \frac{-1.8 \pm 2.498}{2}$, i.e. -2.15 and 0.35.
- The feasible sessions are $-2.15 \leq x_1 \leq 0.35$: B must send less than at $x_1 = 1$.

The least-squares lie

- A linear residual detector scores $\mathbf{r} = A(\mathbf{x} + \delta)$ and alarms when $\|\mathbf{r}\|$ exceeds t.
- The attacker fixes $\delta_s = \Delta$ on the target sensor and chooses $\mathbf{z}$ on the other owned sensors C to minimise $\|A_s\Delta + A_C\mathbf{z}\|$.
- The solution is $\mathbf{z} = -(A_C^\top A_C)^{-1} A_C^\top A_s \Delta$, a least-squares fit; the residual that remains is the part of $A_s\Delta$ outside the span of the owned columns.
- With every sensor owned, δ can lie inside the normal subspace and the residual vanishes.

CUSUM as a sequential test

- Under normal operation $z_t = (r_t - \mu)/\sigma$ has mean 0; under a shift of size δ it has mean δ.
- The log-likelihood ratio of "shift" vs "no shift" for one sample is $\delta z_t - \delta^2/2$; with $k = \delta/2$ it is proportional to $z_t - k$.
- S_t is the largest sum of these log-ratios over windows ending at t (the $\max(0, \cdot)$ restarts after evidence against a shift).
- k is half the smallest shift worth detecting; h trades delay against false alarms (Page 1954).

References

Biggio, Battista, Igino Corona, Davide Maiorca, et al. 2013. “Evasion Attacks Against Machine Learning at Test Time.” European Conference on Machine Learning and Knowledge Discovery in Databases (ECML PKDD).

Han, Dongqi, Zhiliang Wang, Ying Zhong, et al. 2021. “Evaluating and Improving Adversarial Robustness of Machine Learning-Based Network Intrusion Detectors.” IEEE Journal on Selected Areas in Communications 39 (8).

Kravchik, Moshe, and Asaf Shabtai. 2020. Can’t Boil This Frog: Robustness of Online-Trained Autoencoder-Based Anomaly Detectors to Adversarial Poisoning Attacks.

Page, E. S. 1954. “Continuous Inspection Schemes.” Biometrika 41 (1/2).

Rubinstein, Benjamin I. P., Blaine Nelson, Ling Huang, et al. 2009. “ANTIDOTE: Understanding and Defending Against Poisoning of Anomaly Detectors.” ACM SIGCOMM Internet Measurement Conference (IMC).

Vassilev, Apostol, Alina Oprea, Alie Fordyce, Hyrum Anderson, Xander Davies, and Maia Hamin. 2025. Adversarial Machine Learning: A Taxonomy and Terminology of Attacks and Mitigations. NIST AI 100-2e2025. National Institute of Standards; Technology. https://doi.org/10.6028/NIST.AI.100-2e2025.

Wagner, David, and Paolo Soto. 2002. “Mimicry Attacks on Host-Based Intrusion Detection Systems.” ACM Conference on Computer and Communications Security (CCS).